STORY-012 Citizen Dashboard, with Staff Access: evidence

STORY-012 works on the demo deployment, with synthetic data; it is not operating in production. A registrant now has one dashboard with each application, its status and the next step; their exemption eligibility with reasons, and what their profile is missing; the latest events across their cases; and notifications. It shows only their own data. Internal notes, assignments and compliance reviews stay with staff, through the same rule the case page uses.

Staff Access, the owner's decision of October 12: case-manager access is now granted in the app by an existing case manager, never by registering. An address on the CASE_MANAGER_EMAILS list used to become staff for whoever registered it first; the list now only sets up an empty system and never removes anyone. A grant or removal needs a reason. It cannot be applied to yourself or to the last case manager, it is recorded in the Security Audit Log in the same transaction as the change, and the person is notified. A database lock stops two managers removing each other at the same moment; the work found that race and showed it could leave no case managers at all.

Fixed along the way: the Security Audit Log recorded a Cloudflare address for every visitor, because the demo API is reached through Cloudflare. The owner's screenshot showed several Cloudflare addresses for one visitor within seconds. The log now records the visitor's own address, and the deploy check compares it with the address Cloudflare reports for the checking machine.

Screens 1 to 6 come from an automated run against a local copy of the deployed code, because the demo site has no test case-manager accounts. Screens 7 and 8 are the deployed demo site.

Checks

- Demo deployment (scripts/verify-deploy.mjs): the API and the site serve 68e0274; all 10 page paths (now including /staff) serve the current build; database ok; 16 migrations applied; 46 routes in the access table (42 before this story: Staff Access adds 3, the citizen dashboard 1); all 24 protected GET routes answer 401 without a token; the audit log records the caller’s own address (18.89.140.134, the address Cloudflare reports for the checking machine).
- On the demo deployment, signed in as a synthetic citizen (scripts/verify-live-citizen.mjs): all 14 staff GET routes answer 403 (now including GET /api/staff), no staff links show (now including Staff Access), and the dashboard lists the citizen dashboard as done.
- Accessibility audit on the demo deployment (scripts/a11y/audit.mjs --live, signed out and as the synthetic citizen, creating no records): 4 of 4 pages pass every check with 0 axe WCAG A/AA issues, including the new citizen dashboard; both form checks pass.
- Evidence run, local (scripts/evidence/story-012.mjs), 21 checks passed. On an empty system, Dana bootstraps as the first case manager. Sam is on the email list but registers as a citizen and is refused the staff pages. The dashboard lists both of Jordan's applications, the decisions and unread notifications. The internal note and the SSN never reach the applicant, and another applicant sees only their own dashboard. Dana grants Sam access on Staff Access, with a reason and an in-place confirmation. Sam can then open the staff pages and is told who granted access, but cannot remove his own access. The audit log shows both grants, with who, why and how.
- Accessibility audit, local (scripts/a11y/audit.mjs): 13 of 13 page and role combinations pass WCAG 2.1 AA checks, adding /staff; the citizen dashboard is the applicant's /dashboard. Both forms, the session warning and the UI sign-out check also pass.
- Unit tests: 258 passed, including 35 new for the Staff Access rules and 26 for the dashboard. They were checked by breaking the code: registration ignoring existing staff, the bootstrap ignoring staff, the lock removed, self-removal allowed, staff events leaking to the dashboard. API end to end, local (scripts/e2e): 169 checks passed: access 33, case workflow 26, compliance 30, freshness 16, audit 30, staff 34.

Screens

1. Jordan Rivera's dashboard
2. A new registrant
3. Giving case-manager access
4. Access granted
5. Every role change in the audit log
6. The new pages pass the accessibility audit
7. Demo site: the citizen dashboard
8. Demo site: the audit passes

Notes

- A person granted access must sign in again to see the staff pages; the API applies the change at once. The notification says so.
- As decided, a case manager can grant case-manager access to others. A production system would keep that to an administrator or require a second approver; meanwhile every grant is in the audit log with who, why and when.
- On the demo site, an address on the old email list that has not registered yet (Ali's, if he has not) will register as a citizen until a case manager grants access on Staff Access.
- The case manager, admin and leadership dashboards are STORY-013 to STORY-015.
- All data shown is synthetic.

1. Jordan Rivera's dashboard

Two applications: Type A approved ('Exemption granted. Nothing more to do.') and Type B appealed after a denial ('Your appeal is waiting for review.'). Below them: eligibility with reasons, recent activity across both cases, and notifications. The internal note a case manager added to Type B is not on the page.

SSS Modernization
Platform Dashboard

Dashboard | Profile & Exemptions | Logout

Demo environment. Synthetic data only. Do not enter a real SSN.

Welcome, Jordan Rivera. Your applications, eligibility, case history and notifications are all here.

Your applications

Type B - Income-Based Exemption — Appealed

Submitted
10/12/2026, 9:57:40 PM

Last update
10/12/2026, 9:57:42 PM

Case manager
Assigned

Next step: Your appeal is waiting for review.

View your Type B case

Type A - Senior Exemption — Approved

Submitted
10/12/2026, 9:57:40 PM

Last update
10/12/2026, 9:57:41 PM

Case manager
Assigned

Next step: Exemption granted. Nothing more to do.

View your Type A case

Notifications 7 new

Mark all read

Your Type B exemption case is now Appealed.
10/12/2026, 9:57:42 PM

Your Type B exemption case is now Denied. Reason: The income statement on file is from 2024; please upload a current one.
10/12/2026, 9:57:41 PM

Your Type A exemption case is now Approved.
10/12/2026, 9:57:41 PM

Your Type B exemption case is now In Review.
10/12/2026, 9:57:41 PM

Your Type A exemption case is now In Review.
10/12/2026, 9:57:41 PM

Your eligibility

Type A - Senior Exemption — Eligible
Applicant is 65 or older.
Checked 10/12/2026, 9:57:40 PM

Type B - Income-Based Exemption — Eligible
Annual income is below the $20,000 threshold.
Checked 10/12/2026, 9:57:40 PM

Type C - Hardship Exemption (Pending Review) — Not Eligible
No documented hardship on file.
Checked 10/12/2026, 9:57:40 PM

Your profile passes the compliance check: age 18 or older, with a phone number and an address.

Update your profile

Recent activity

Status changed: Denied → Appealed
10/12/2026, 9:57:42 PM
View your Type B case

Status changed: In Review → Denied
10/12/2026, 9:57:41 PM
View your Type B case

Status changed: In Review → Approved
10/12/2026, 9:57:41 PM
View your Type A case

Status changed: Submitted → In Review
10/12/2026, 9:57:41 PM
View your Type B case

Status changed: Submitted → In Review
10/12/2026, 9:57:41 PM
View your Type A case

Document added: Proof of age
10/12/2026, 9:57:41 PM
View your Type A case

Application submitted
10/12/2026, 9:57:40 PM
View your Type B case

Application submitted
10/12/2026, 9:57:40 PM
View your Type A case

Release Progress

- ✓ R0: Secure registration and sign-in (hashed passwords and SSNs)
- ✓ R0: Compliance guards (demo-data banner, masked SSN entry)
- ✓ R0: Demo deployment online, with a managed database
- ✓ R1: Profile update with compliance check, and exemption eligibility with reasons
- ✓ R1: Case management: applications, review workflow, timeline, notifications, CSV export
- ✓ R1: Compliance validation: every decision checked against 8 controls, with reviews and an audit log
- ✓ R1: Data freshness: every update timed until it is readable, against a 30-second target
- ✓ R1: Security audit log: every sign-in, refusal, data access and change, write-once
- ✓ R1: Accessibility (Section 508): every page checked against WCAG 2.1 AA, by keyboard and screen reader
- ✓ R1: Citizen dashboard: applications, eligibility, case history and notifications in one place
- → R1 (next): Case manager, admin and leadership dashboards

2. A new registrant

Taylor Brooks has just registered: no applications yet, what the profile is missing before eligibility can be checked, and where to start.

SSS Modernization
Platform Dashboard

Dashboard | Profile & Exemptions | Logout

Demo environment. Synthetic data only. Do not enter a real SSN.

Welcome, Taylor Brooks. Your applications, eligibility, case history and notifications are all here.

Your applications

No applications yet. Check your eligibility and apply from Profile & Exemptions.

Notifications

No notifications yet.

Your eligibility

Your eligibility has not been checked yet. Saving your profile checks it.

Your profile does not pass the compliance check yet.
Still needed: Phone number, Address.

Update your profile

Recent activity

No activity yet. Changes to your applications appear here.

Release Progress

- ✓ R0: Secure registration and sign-in (hashed passwords and SSNs)
- ✓ R0: Compliance guards (demo-data banner, masked SSN entry)
- ✓ R0: Demo deployment online, with a managed database
- ✓ R1: Profile update with compliance check, and exemption eligibility with reasons
- ✓ R1: Case management: applications, review workflow, timeline, notifications, CSV export
- ✓ R1: Compliance validation: every decision checked against 8 controls, with reviews and an audit log
- ✓ R1: Data freshness: every update timed until it is readable, against a 30-second target
- ✓ R1: Security audit log: every sign-in, refusal, data access and change, write-once
- ✓ R1: Accessibility (Section 508): every page checked against WCAG 2.1 AA, by keyboard and screen reader
- ✓ R1: Citizen dashboard: applications, eligibility, case history and notifications in one place
- → R1 (next): Case manager, admin and leadership dashboards

3. Giving case-manager access

Dana Whitfield, a case manager, gives Sam Ortiz case-manager access on Staff Access with a required reason, and confirms in place. Sam is on the old email list, but registering no longer made him staff.

Staff Access

Who can work cases, granted in the app and recorded

Dashboard | Profile & Exemptions | Case Management | Compliance | Data Freshness | Audit Log | Staff Access | Logout

Demo environment. Synthetic data only. Do not enter a real SSN.

Case-manager access is granted here by an existing case manager, never by registering. Every change is recorded in the Security Audit Log.

Current staff

Name	Email	Role	Action
Dana Whitfield (you)	dana.whitfield@example.com	Case manager	At least one case manager must keep access.

Give case-manager access

The person needs an account first. Case managers review and decide cases, so give access only to people who need it.

Email

sam.ortiz@example.com

Reason

Second case manager, so every decision can be reviewed by someone else.

Required. Kept in the Security Audit Log with your name.

Confirm: give sam.ortiz@example.com case-manager access?

Confirm access | Cancel

4. Access granted

The change is confirmed and Sam joins the list. Nobody can remove their own access, and the last case manager cannot be removed.

Staff Access

Who can work cases, granted in the app and recorded

Dashboard | Profile & Exemptions | Case Management | Compliance | Data Freshness | Audit Log | Staff Access | Logout

Demo environment. Synthetic data only. Do not enter a real SSN.

sam.ortiz@example.com now has case-manager access.

Case-manager access is granted here by an existing case manager, never by registering. Every change is recorded in the Security Audit Log.

Current staff

Name	Email	Role	Action
Dana Whitfield (you)	dana.whitfield@example.com	Case manager	You cannot remove your own access.
Sam Ortiz	sam.ortiz@example.com	Case manager	Remove access

Give case-manager access

The person needs an account first. Case managers review and decide cases, so give access only to people who need it.

Email

Reason

Required. Kept in the Security Audit Log with your name.

Give access

5. Every role change in the audit log

Filtered to Role granted: the bootstrap that made Dana the first case manager of the empty system, and Dana's grant to Sam with its reason, recorded as via Staff Access.

Security Audit Log

Every sign-in, refusal, data access, change and alert

Dashboard | Profile & Exemptions | Case Management | Compliance | Data Freshness | Audit Log | Staff Access | Logout

Demo environment. Synthetic data only. Do not enter a real SSN.

Write-once
The database refuses any edit or deletion of an entry.

Kept for 7 years
42 entries, 6 of them refusals or failures.

No personal data
SSNs, passwords, codes and tokens are removed before an entry is written.

From: mm/dd/yyyy | To: mm/dd/yyyy | User: Email | Event: Role granted | Area: All | Result: All | Search | Reset

When	User	Event	Area	Result	Details	From
10/12/2026, 9:57:52 PM	dana.whitfield@example.com	Role granted PERMISSION_GRANT	users	Succeeded	sam.ortiz@example.com · reason: Second case manager, so every decision can be reviewed by someone else. · role: case_manager · via: Staff Access	::1
10/12/2026, 9:57:37 PM	dana.whitfield@example.com	Role granted PERMISSION_GRANT	users	Succeeded	dana.whitfield@example.com · role: case_manager · via: CASE_MANAGER_EMAILS bootstrap (no staff yet)	::1

2 entries

Previous | Page 1 of 1 | Next

6. The new pages pass the accessibility audit

13 of 13 page and role combinations pass the WCAG 2.1 AA checks, including the citizen dashboard and Staff Access. The forms, the session warning and the UI sign-out check pass too.

Accessibility audit: 13 of 13 pages pass WCAG 2.1 AA checks

http://localhost:4173 · 2026-10-13 02:59 UTC · axe-core 4.10.2 (rules tagged wcag2a, wcag2aa, wcag21a, wcag21aa) in Chrome, plus keyboard, title, structure and 320 px reflow checks. Synthetic data.

Signed in as	Page	axe A/AA issues	Tab stops	WCAG A/AA rules	Every control reached by Tab	Focus always visible	Descriptive title	One h1 and one main	Skip link first	Reflow at 320 px
Signed out	`/login`	0	4 of 4	Pass	Pass	Pass	Pass	Pass	Pass	Pass
Signed out	`/register`	0	8 of 8	Pass	Pass	Pass	Pass	Pass	Pass	Pass
Applicant	`/dashboard`	0	13 of 13	Pass	Pass	Pass	Pass	Pass	Pass	Pass
Applicant	`/profile`	0	12 of 12	Pass	Pass	Pass	Pass	Pass	Pass	Pass
Applicant	`/cases/:id`	0	8 of 8	Pass	Pass	Pass	Pass	Pass	Pass	Pass
Case manager	`/dashboard`	0	10 of 10	Pass	Pass	Pass	Pass	Pass	Pass	Pass
Case manager	`/cases`	0	17 of 17	Pass	Pass	Pass	Pass	Pass	Pass	Pass
Case manager	`/cases/:id`	0	19 of 19	Pass	Pass	Pass	Pass	Pass	Pass	Pass
Case manager	`/compliance`	0	14 of 14	Pass	Pass	Pass	Pass	Pass	Pass	Pass
Case manager	`/compliance/audit`	0	38 of 38	Pass	Pass	Pass	Pass	Pass	Pass	Pass
Case manager	`/freshness`	0	13 of 13	Pass	Pass	Pass	Pass	Pass	Pass	Pass
Case manager	`/audit`	0	18 of 18	Pass	Pass	Pass	Pass	Pass	Pass	Pass
Case manager	`/staff`	0	13 of 13	Pass	Pass	Pass	Pass	Pass	Pass	Pass

Failed submits

Form	Announced alert	Invalid fields	Described by their message	Focus on first invalid field	axe issues	Result
Sign in, wrong password	Invalid email or password	0	0	no	0	Pass
Registration, empty	none	5	5	yes	0	Pass

Session about to end (WCAG 2.2.1 Timing Adjustable)

Warning shown 2 minutes before	axe issues	Modal, named and described	Focus on Stay signed in, kept inside	Escape extends: new 1-hour token, same sign-in time	No action: signed out, told why	Result
yes	0	yes	yes	yes	yes	Pass

Found in our own earlier work: sign-out from the UI

Logout button, then the audit log: sign-out recorded: yes; logged as a refused request: no.

What a screen reader is told about the registration form after an empty submit

Role	Accessible name	Description	Required	Invalid
textbox	Email Address	Email is required	yes	yes
textbox	Full Name	Full name is required	yes	yes
textbox	Password	Password is required	yes	yes
button	Create Account			
textbox	Social Security Number	SSN is required	yes	yes
button	Show			
button	Show date picker Show date picker	Date of birth is required		

Best-practice advisories (not WCAG failures)

None.

7. Demo site: the citizen dashboard

The deployed demo site after the deploy, signed in as the synthetic citizen used by the checks: the new dashboard (this account has no applications) and no staff links.

SSS Modernization
Platform Dashboard

Dashboard | Profile & Exemptions | Logout

Demo environment. Synthetic data only. Do not enter a real SSN.

Welcome, Deploy Check. Your applications, eligibility, case history and notifications are all here.

Your applications

No applications yet. Check your eligibility and apply from Profile & Exemptions.

Notifications

No notifications yet.

Your eligibility

Your eligibility has not been checked yet. Saving your profile checks it.

Your profile does not pass the compliance check yet.
Still needed: Phone number, Address.

Update your profile

Recent activity

No activity yet. Changes to your applications appear here.

Release Progress

- ✓ R0: Secure registration and sign-in (hashed passwords and SSNs)
- ✓ R0: Compliance guards (demo-data banner, masked SSN entry)
- ✓ R0: Demo deployment online, with a managed database
- ✓ R1: Profile update with compliance check, and exemption eligibility with reasons
- ✓ R1: Case management: applications, review workflow, timeline, notifications, CSV export
- ✓ R1: Compliance validation: every decision checked against 8 controls, with reviews and an audit log
- ✓ R1: Data freshness: every update timed until it is readable, against a 30-second target
- ✓ R1: Security audit log: every sign-in, refusal, data access and change, write-once
- ✓ R1: Accessibility (Section 508): every page checked against WCAG 2.1 AA, by keyboard and screen reader
- ✓ R1: Citizen dashboard: applications, eligibility, case history and notifications in one place
- → R1 (next): Case manager, admin and leadership dashboards

8. Demo site: the audit passes

The accessibility audit on the deployed demo site after the deploy, signed out and as the synthetic citizen: sign-in, registration, the citizen dashboard and the profile all pass.

Accessibility audit: 4 of 4 pages pass WCAG 2.1 AA checks

https://sss-demo-frontend.onrender.com · 2026-10-13 03:01 UTC · axe-core 4.10.2 (rules tagged wcag2a, wcag2aa, wcag21a, wcag21aa) in Chrome, plus keyboard, title, structure and 320 px reflow checks. Synthetic data.

Signed in as	Page	axe A/AA issues	Tab stops	WCAG A/AA rules	Every control reached by Tab	Focus always visible	Descriptive title	One h1 and one main	Skip link first	Reflow at 320 px
Signed out	`/login`	0	4 of 4	Pass	Pass	Pass	Pass	Pass	Pass	Pass
Signed out	`/register`	0	8 of 8	Pass	Pass	Pass	Pass	Pass	Pass	Pass
Applicant	`/dashboard`	0	6 of 6	Pass	Pass	Pass	Pass	Pass	Pass	Pass
Applicant	`/profile`	0	10 of 10	Pass	Pass	Pass	Pass	Pass	Pass	Pass

Failed submits

Form	Announced alert	Invalid fields	Described by their message	Focus on first invalid field	axe issues	Result
Sign in, empty	none	2	2	yes	0	Pass
Registration, empty	none	5	5	yes	0	Pass

What a screen reader is told about the registration form after an empty submit

Role	Accessible name	Description	Required	Invalid
textbox	Email Address	Email is required	yes	yes
textbox	Full Name	Full name is required	yes	yes
textbox	Password	Password is required	yes	yes
button	Create Account			
textbox	Social Security Number	SSN is required	yes	yes
button	Show			
button	Show date picker Show date picker	Date of birth is required		

Best-practice advisories (not WCAG failures)

None.